

软件开发综合能力实践（网络软件与安全）
要求说明

长安大学信息工程学院
软件工程专业
2026 年 8 月

一、概述

综合实践（网络软件与安全）面向一个 Web 系统展开 Web 前端功能与后台功能的设计与开发任务。Web 前端主要向用户展示一个高校成绩管理系统的基本功能,后台须对 Web 前端提交数据进行处理。整个系统须从网络数据传输安全、数据持久存储安全、操作访问权限控制、敏感数据在网络空间不可篡改等方面进行安全设计。

每组学生根据自身人员组成以及技术能力,用面向对象方法学建模方法和工具进行分析和设计,并选择合适的面向对象语言全部实现或部分实现功能,并给出相应的测试结果,指导教师根据各组学生完成代码以及文档的质量进行综合实践评分。

二、需求概要

（1）基于 Web 的高校成绩管理系统功能需求

系统角色包括教师、学生和管理员。教师主要负责录入考试成绩、录入成绩分析表和查看查看往年课程成绩情况；学生可查看成绩。管理员则对录入的成绩进行管理；系统提供三类角色的权限安全控制。系统的功能在 Web 前端的浏览器中呈现并使用，后台对 Web 前端提交的数据进行处理。这部分功能是综合实践的基本要求，如果这部分要求没有实现，综合实践考核将不合格。

（2）系统后台数据处理功能需求

系统后台能与 Web 前端功能解耦并实现复用，后台功能应具有对 Web 前端提交数据统一接收以及自动形成 SQL 语句并进行事务处理的分布式部署能力。这部分功能是综合实践的扩展要求，当学生后台功能不具有“分布式部署能力”时，综合考核将直接降档次评估。

（3）系统安全约束需求

系统功能须从 Web 前端页面功能安全、数据传输安全、操作访问权限访问控制、数据持久存储安全以及敏感数据不可篡改等诸多方面进行安全权衡并给出安全性措施和相应的安全测试。这部分功能是综合实践的扩展要求，即当学生没有实现或仅仅实现少部分，综合考核将直接降档次评估。

每个小组同学须根据必要性和小组能力细化这方面需求并反映在小组项目报告当中。

三、参考体系逻辑架构及其功能

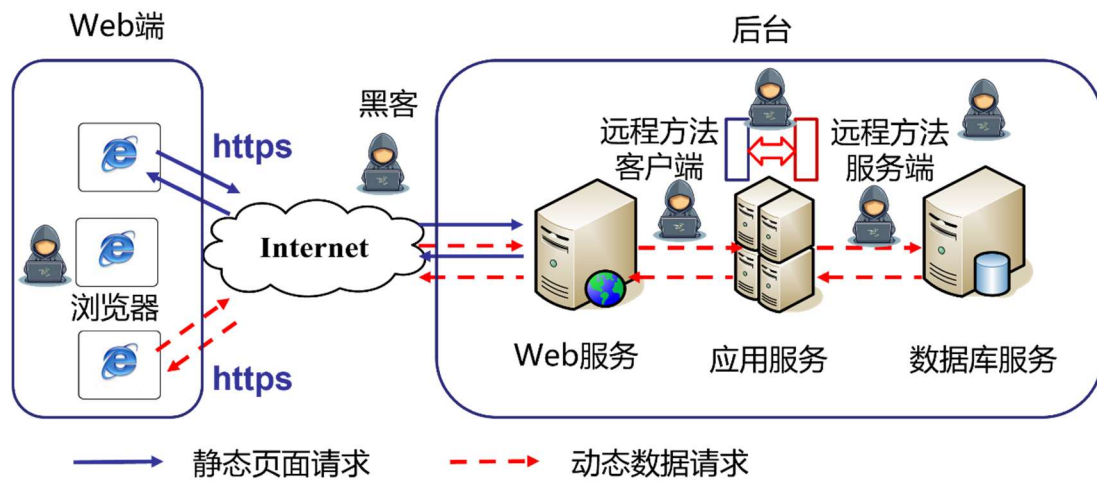


图 1 展示了本综合实践项目设计任务的参考体系逻辑架构，列举出了需要认真对待的可能安全隐患点，包括 Web 前端页面功能安全、数据传输安全、操作访问权限访问控制、数据持久存储安全以及敏感数据不可篡改等方面。

图中的 Web 服务和应用服务在实际的物理架构中可以进行合并。在后台融入网络软件常用的远程方法调用技术，在远程方法调用客户端实现对 Web 前端功能传来的数据自动搜集，在远程方法调用的服务端来实现数据库操纵语句的自动拼接与事务操作。

四、 基于 Web 的高校成绩管理系统具体要求

1. 高校成绩管理系统背景

高等院校担负着我国培养专门人才的重要任务，高校教务管理部门作为教育教学实施中的主要管理部门，日常需要完成各类各专业学生的教学管理、教务管理等繁琐复杂的事务性工作。近年来，随着信息技术的飞速发展，高校教务管理信息化进程也不断推进，尤其是大量教学管理相关计算机软件的普遍应用，信息化程度正在不断深化，其中基础课程、专业课程教学的 CAI 软件，学生管理、学籍管理、成绩管理等教务管理软件的发展与应用日趋成熟。

然而，许多高校在教务管理办公过程中，却依然沿用着传统人工管理的工作方式处理教材管理、实验管理、实践教学管理、考务管理、教师工作量管理、教学检查、教学研究及研究生管理等方面的业务。这些业务信息在办公过程中会频繁使用，尤其是业务问询十分频繁，文件及资料的查阅频度也相当高。对此，人工管理方式在管理效率与效能方面的制约是十分明显的。不仅使办公人员长期处于很高的工作强度的压力之中，同时也越来越明显地形成了办公对教学管理服务的瓶颈，因此对这种现状的改变已经成为当前亟待解决的问题。

因此我们拟设计并开发一套高校教务管理办公系统软件，通过对以上问题的深入调研、分析，挖掘其中存在的有价值的信息与联系，运用已有的数据库知识结合软件设计技术、方法与工具，设计并完成该办公系统软件及其文档，力求能够对解决实际问题产生有效的帮助。

2. 实践项目功能需求

考虑到该系统的复杂性以及综合实践的时间限制，我们选择教务管理系统中的一个子系统“基于 Web 的高校成绩管理系统”，作为本次综合实践设计的题目。根据系统背景及功能需求，系统用户共分为教师、学生和管理员三个角色，其中：

(1) 教师

1) 教师录入考试成绩

- 成绩类别选择（百分制）
- 成绩系数设置（平时成绩，考勤，作业，实验，期中、期末考试等各项所占总成绩比例）
- 成绩录入（区分正考成绩，补考成绩）
- 成绩暂存
- 成绩提交
- 成绩撤销
- 成绩查看
- 成绩打印（选做）

2) 教师录入成绩分析表

- 成绩统计表生成（无成绩分析）
- 成绩分析录入
- 成绩统计分析表显示
- 成绩统计分析表打印（选做）

3) 教师查看往年课程成绩情况

课程查找（根据学年学期查找，根据课程名称查找）

（2）学生

成绩查看

- 本人本学期成绩查看
- 本人在校课程成绩一览表查看，成绩浏览要体现正考分数，补考分数，例如 58/57。补考卷面分数如果超过 60 分，就打 60 分。如果未超过 60 分，就打卷面实际分。
- 本人在校课程成绩一览表打印（选做）
- 本人成绩排名
- 成绩通知（选做）
- 挂科统计红灯警告（选做）

（3）管理员

1) 成绩录入管理

- 小撤销：将教师提交的成绩状态由“已提交”状态转为“暂存”状态，撤销后教师可重新修改已录入的成绩，并进行提交。
- 大撤销：将教师提交的成绩记录完全删除，即教师需重新完成成绩的录入和提交工作。

2) 管理员人员组织库维护与权限分配管理

- 管理员可以对教师、学生以及其他管理员进行组织库信息录入和维护。

- 可以对学生和教师的功能中的查询、录入与维护权限进行分配，也可对其他管理员的权限进行分配。

3) 管理员重要信息安全管理

- 如果数据库中的学生成绩被篡改了，管理员可以不依赖于数据库信息查出原始成绩。
- 对于数据库中的每一次敏感信息进行维护要形成日志，维护日志将在数据库和网络中共同进行记录。

(4) 功能 AI

1) 成绩异常智能检测

- 教师录入成绩后，系统自动检测异常值（如全班平均分偏差过大、某学生成绩与历史成绩波动剧烈、补考成绩异常高/低）。
- 检查约束要求。基于统计规则（均值±3 标准差、百分位阈值、以及其它规则）
- 安全要求。检测到异常时触发审计日志，并提醒管理员复核，符合“安全审计”和“数据完整性”要求。

2) 成绩智能预测与学业预警

假设一门课的总评成绩公式是：总评 = 平时出勤×30%+作业实验×20%+期末成绩×50%。现实中，很多老师在期末前已经知道平时分和实验分了，唯独不知道期末考多少。这就需要根据学生已经产生的历史数据（如平时出勤和已有课程成绩），推算他在当前课程中

可能取得的最终成绩区间。这需要寻找多个影响因素（自变量 X）与最终成绩（因变量 Y）之间的统计关系。

- 基于学生历史成绩，预测当前学期可能挂科的课程，并给教师/学生推送预警，可放在教师“成绩分析表”模块中，作为扩展图表展示。
- 简单线性回归模型预警方法要求。模型不是“猜”，而是“用历史规律推算当前”。只要历史数据足够，线性回归完全能捕捉到这种线性相关性。需要**收集至少 3 年历史数据，如某门课的“平时+实验”组合与“期末实际分数”**的数据对。**建立线性模型：** $\text{期末} \approx a \times \text{平时} + b \times \text{实验} + c$ 线性回归会自动算出 a、b、c 的值，使得这个公式在历史数据上误差最小。**进行预测：**当前学生的平时分和实验分代入，就得到一个**估计的期末分**。
- 决策树非线性模型预警方法要求。如果成绩规律不是线性的，比如：平时分 > 90 且实验 > 80 → 期末基本 > 85，平时分 70~80 且实验 ≥ 70 分 → 期末大概率 < 60 分，这种“条件-结论”式的规则，正是决策树的强项。它会自动从历史数据中学习出类似这样的分支规则，并用它对新生进行预测。决策树训练完成后，可以把树的结构打印出来，直接作为“成绩分析表”的一部分，告诉老师“根据历史数据，满足 XX 条件的学生容易挂科”，这对于教务管理非常有实际意义。
- 预测效果。绝对准确不可能（因为期末考试本身有随机性），但不追求 100% 准确，而是追求趋势判断：如预测结

果 <55 →触发“挂科预警”；预测结果比历史平均低很多→触发“成绩异常检测”；这就是“学业预警”和“异常检测”功能——它们不要求模型完美，只需要比纯人工判断更客观、更自动化。

- 预测结果涉及隐私仅学生本人和教师可见。预测结果不存储，仅展示，不写入正式成绩库（避免被误认为“改成绩”）。功能放在后台，作为一个独立的工具类或微服务，仅在教师或管理员主动点击“生成预警”时运行，不干扰主业务流程。

3) 智能成绩录入辅助

- 教师在录入大量成绩时，支持语音录入或 OCR 识别纸质成绩单，自动填充表单。可调用公有云 API 资源（如百度语音、阿里云 OCR）进行前端集成。
- 安全注意：传输加密 + 临时存储即销毁。

4) 区块链安全约束要求

- 用区块链记录成绩关键操作（提交、撤销、大撤销），同时用 AI 模型分析操作日志，识别**非正常操作模式**（如深夜批量修改、非授课教师频繁修改）。
- **实现方式**：区块链用简易实现（如 Hyperledger Fabric 或以太坊测试链）。AI 用 LSTM 或 Transformer 对时序操作日志做异常分类。
- **安全结合点**：直接命中“敏感数据不可篡改”和“日志审计”硬核要求。

五、系统后台远程方法调用具体要求

后台选用一种或几种结合的远程方法调用技术，即 CORBA（对象请求代理）、DCOM（分布式组件对象模型）、JMS（Java 消息服务）、RMI（远程方法调用）、Webservice（Web 服务）等，设计远程方法调用客户端和服务端，从而体现“物理上分布，逻辑上统一”的网络软件的分布式结构特征。

1 远程方法调用客户端

- 客户端宿主是一个可处理 Web 前端 HTTPS 请求统一入口的容器。
- 客户端实现对 Web 前端功能传来的数据统一处理。Web 前端无论是插入功能页面、修改功能页面、删除功能页面以及查询功能页面都统一提交至远程方法调用客户端。客户端采用合适的数据结构对象存放和表达相应的功能数据，包括但不限于数据字段、数据值、表名以、SQL 查询以及 SQL 操作语句的类型（Insert、Update 和 Delete），这里的数据查询语句不与数据操纵语句混合。
- 在客户端和 Web 前端页面建立数据命名约定，从而使客户端能识别 Web 前端传来数据的关键字和非关键字，也要考虑对多表进行多类型操作的可能性，也可考虑对多表进行有关联查询的可能性。
- 客户端针对 SQL 查询以及 SQL 操作语句的类型分别调用服务端的 SelectInterface 或 ManipulationInterface 远程接口，并将数据结构对象值传递到服务端。

- 客户端针对远程调用结果进行 Web 前端页面显示设计，包括分页显示设计。

2 远程方法调用服务端

- 服务端提供接口 `SelectInterface` 或 `ManipulationInterfac` 分别负责数据查询、数据操纵。`SelectInterface` 返回类型为二维字符串数组，`ManipulationInterfac` 返回为布尔类型。
- “服务端接口实现”对可值传递的数据结构对象接收并进行解析，识别出数据字段、数据值、表名，识别出数据操纵的具体类型，即 `Insert`、`Update` 和 `Delete`。
- 自动拼接数据查询语句。
- 自动拼接数据操纵语句，可根据数据库表中的字段数字与字符串类型自动在拼接的 SQL 语句中是否加单引号。
- 服务端接口实现可根据配置文件设置自适应连接主流数据库（MySQL、SQLServer、Oracle 等）。
- 服务端对于多条数据操纵语句可自动构成事务进行统一处理。

3 实现步骤参考建议

- （1）首先熟悉一种远程方法调用的分布式对象技术。
- （2）对选定的远程方法调用进行对象值传递，实现客户端和服务端的通讯。
- （3）进行 `SelectInterface` 和 `ManipulationInterface` 接口设计和使用，再进行传输安全设计考虑。

六、系统安全性具体要求

1 软件开发与网络安全的关系

在软件开发过程中，网络安全设计占据着至关重要的地位。软件开发与网络安全之间存在着密不可分的联系，一方面软件开发负责构建各类网络应用系统（如学生成绩管理系统），为用户提供便利的功能与服务；另一方面，网络安全作为软件开发过程中的重要环节，确保软件应用的安全性和用户数据的保密性。

（1）软件开发与网络安全之间关系：

- 功能性与安全性的平衡
- 安全漏洞与风险评估
- 安全编码实践的重要性
- 软件测试与漏洞检测
- 持续监控与更新

（2）网络安全设计的原则

- 安全性：网络安全设计应确保网络系统的完整性和可靠性，防止数据被篡改或破坏。
- 可用性：网络安全设计应确保网络系统的可用性，使用户能够正常地访问和使用网络资源。
- 保密性：网络安全设计应确保网络应用系统中敏感数据的保密性，防止数据泄露给未经授权的用户。

（3）网络安全设计的主要内容

- 网络隔离：通过防火墙、入侵检测系统等技术手段，将网络划分为多个独立的区域，限制不同区域之间的通信，从而降低网络攻击的风险。
- 访问控制：通过身份认证、权限管理等措施，控制用户对网络资源的访问和操作，防止未经授权的访问和数据泄露。
- 数据加密：通过对敏感数据进行加密处理，确保数据在传输和存储过程中的安全性。
- 安全审计：通过对网络应用系统的日志进行分析和审计，发现和处理潜在的安全威胁。

(4) 网络安全设计的常用技术

- 防火墙技术：通过设置访问控制列表和过滤规则，阻止未经授权的访问和数据泄露。
- 入侵检测系统：通过实时监控网络流量和系统日志，发现和处理潜在的网络攻击。
- 数据加密技术：通过对敏感数据进行加密处理，确保数据的安全性和保密性。
- 虚拟专用网络（VPN）技术：通过建立加密通道，实现远程访问和数据传输的安全性。

2 基于 Web 的成绩管理系统的安全性要求

(1) 安全性需求

在系统的需求分析阶段，除了给出系统的功能性需求外，还应该给出系统的安全性需求。系统的安全性需求可以从安全目标（实现系统数据的保密性、完整性、可用性和真实性等）、潜在威胁（网络攻击、恶意软件、SQL 注入、缓冲区溢出等）、安全规划（身份认证、访问控制、数据加密等）、安全评估（漏洞扫描和安全性测试等）等方面考虑。

（2）软件系统安全架构设计

软件安全架构旨在确保软件系统在开发、运行、维护等全生命周期的安全性。它通过构建一系列的安全组件和安全策略，增强软件对各种网络安全威胁的防范能力。在《基于 Web 的成绩管理系统》的设计中，可以从以下七方面考虑：

- 身份认证模块（如支持多种身份验证方式，确保用户身份的真实性）
- 访问控制模块（对用户访问系统资源的权限进行管理，如对教师、学生、管理员三类用户的访问控制）
- 数据加密模块（通过数据加密算法实现敏感数据（学生成绩）在传输和存储过程中不被泄露，保护数据的保密性和完整性）
- 漏洞防御机制（通过安全扫描和漏洞评估，及时发现和修复系统的安全漏洞）
- 安全通信协议（如使用 SSL/TLS，确保数据传输的安全性）

- 安全审计与日志（通过收集和分析系统日志，可追踪系统安全事件和审计用户行为，及时发现异常行为和安全事件）
- 应急响应机制（以应对可能的安全事件和攻击，包括应急预案、应急资源准备级响应团队等）

为实现以上系统安全设计，可以采用分层的安全架构，如：

- 应用层：负责处理用户请求和业务逻辑，其安全职责负责实施业务逻辑层面的访问控制和安全策略，确保用户只能访问其权限范围内的资源。
- 服务层：提供一系列服务接口，其安全职责提供身份认证和授权机制，确保只有经过认证的用户才能访问相应的服务。
- 数据访问层：负责与数据库进行交互，实现数据的存储和检索，其安全职责是实施数据加密和备份策略，防止数据泄露和丢失。
- 网络层：处理数据传输过程中的安全问题，其安全职责是部署防火墙、入侵检测系统等安全软件/设备，监控和控制数据传输过程中的安全风险。

(3) 系统安全措施的实现

- 数据加密：对敏感数据进行加密处理，以防止未经授权的访问和数据泄露，可使用 AES、RSA 加密算法来实现。

- 身份认证和授权：实施严格的身份认证机制，确保只有经过授权的用户才能访问系统资源。可使用数字证书技术来加强身份验证过程。
- 访问控制：根据用户的角色和权限设置不同的访问级别，限制对敏感数据的访问。如采用基于角色的访问控制（RBAC）模型来实现。
- 漏洞扫描和渗透测试：定期对漏洞扫描和渗透测试，发现并修复系统的安全隐患。可以使用自动化工具（如OpenVAS）来执行。
- 安全审计和监控：建立安全审计和监控系统，实时监测系统的安全状况。可以使用日志分析工具来收集和分析安全事件。
- 代码审查和静态分析：定期进行代码审查和静态分析，确保代码中没有安全漏洞，可以使用静态代码分析工具（如SonarQube）来辅助。

(4) 系统安全测试与漏洞检测

- 在系统测试阶段，除功能测试外，还需进行安全测试和漏洞扫描，以确保软件系统的整体安全性和用户数据的保密性。

(5) 系统功能安全设计思路

Web 信息管理系统的网络安全设计，核心是“层层防护、重点突出”——以身份认证和访问控制为入口，以数据安全为核心，以接口安全为关键，配合服务器加固和日志监控，形成完整的安全体

系。学生在实践中，需结合系统的业务场景（如是否存储敏感数据、是否有多人协作权限），针对性选择安全设计方案，既保证系统安全可用，又控制实现难度，符合高年级综合实践的考核要求。学生无需追求所有安全特性，优先落地“密码哈希存储、HTTPS、接口权限校验、SQL 注入防护、XSS 转义”，这些是 Web 系统的基础安全要求，实现难度低、效果显著；学生实践注意事项如下：

1) 使用成熟工具简化开发：

- 权限框架：如 Spring Security (Java)、Django Auth (Python)；
- 加密工具：BCrypt 库、JWT 库；
- 安全扫描：OWASP ZAP（手动扫描接口漏洞）、SonarQube（代码质量与安全检测）；

2) 在设计文档中体现安全思考

即使部分安全特性未完全实现（如多因素认证），也需在文档中说明“设计思路、计划实现方案、当前简化版本的局限性”，体现对安全的全面考量；

3) 避免常见安全坑：

- 禁止硬编码密钥 / 密码；
- 禁止在前端拼接 SQL 操纵语句；
- 禁止忽略 HTTPS；

- 禁止信任用户输入（任何输入都需校验）。

（6）数据库持久存储安全

- 访问权限控制，即用户不能访问权限外的表。
- 数据安全，成绩的隐私，可结合可搜索加密与保序加密实现高安全性的数据库管理。
- 操作权限控制。实现多个管理员情况下的或签等功能。

（7）网络去中心化安全

可结合区块链技术考虑去中心化的数据管理模式：比如使用区块链记录所有管理员的操作记录以保持公开可审计性，也可进一步将所有课程以及成绩数据都存在区块链上，后续结合可修订区块链技术进行对数据的公开修改，此应用中强调对数据操作权限的管理，隐私性要求较低。

七、成果提交形式

学生完成综合实践（网络软件与安全）后，每个小组按照组别提交电子文件压缩包和打印版文档。

1 电子文件压缩包命名要求

- 压缩包的名字命名为“第 X 组”。压缩文件中的目录分别为：“1 答辩 PPT”、“2 项目报告”、“3 个人报告”、“4 系统代码”、“5 模型文件”。
- “1 答辩 PPT”。封面给出题目、小组类别、组长学号和姓名、组员的学号和姓名；汇报内容包括“系统的总体架构”、“基于 Web 的高校成绩管理系统设计实现要点”、“XX 远程调用方法客户端和服务端设计实现要点”、“系统安全设计实现要点”。
- “2 项目报告”目录下存放文件命名为“第 X 组项目报告”
- “3 个人报告”目录下各组员的文件名命名为“学号+姓名”。
- “4 系统代码”目录下建立“Web 前端网络设计”、“Web 后端网络设计”、“安全设计”子目录；“Web 后端网络设计”的子目录分别为“远程方法客户端”、“远程方法服务端”，将源程序或建模文件分别放入相应目录；“安全设计”下根据考虑的安全措施分别建立相应的子目录放置源程序。

- “5 模型文件”目录下建立“数据库设计建模文件”和“UML 建模设计文件”。

2 打印版文档要求

(1) 项目整体报告格式要求

参见模版

按照软件工程方法学要求阐述需求、概要设计、详细设计、测试关键内容，关注这些阶段的内在联系性。

(2) 个人报告格式要求

格式参见模版

按照个人在实践承担的任务编写，需要与项目整体报告中的“工作任务分解表”中各成员承担任务一致。具体格式如下：

“任务 X：任务名称描述”

“任务完成情况描述：”

八 成绩评定依据

以小组汇报的方式考察，汇报 20 分钟，回答 10 分钟。

课程总成绩=答辩成绩×70%+过程考核成绩×30%

过程考核成绩由组长给组员包括自己进行综合评定。教师参考组员成绩并通过时长约为 10 分钟的答辩对组长评定结果进行复核并形成答辩成绩，并给出每个学生的课程目标达成度。

表 1. 答辩以及过程考核学生能力评价

得分	评价标准
不合格 <60	学生无法展现其需求问题规格说明和设计问题分析能力，部分实现综合实践功能；学生不了解自己负责的任务技术；在演示代码中没有自己负责的部分或对自己演示代码不太理解；学生没有自己文档写作或文档写作的格式不规范；学生不具有基本的逻辑表达和答辩能力；学生在团队协作中表现差，很难融入团队当中。
$60 \leq$ 合格 <70	学生基本展现其需求问题规格说明和设计问题分析能力，部分实现综合实践功能；学生基本了解自己负责的任务技术；在演示代码中有自己负责的部分或对自己演示代码基本理解；学生有自己文档写作或文档写作的格式初步有规范；学生具有基本的逻辑表达和答辩能力；学生能表现出基本团队协作。
$70 \leq$ 中等 <80	学生较好展现其需求问题规格说明和设计问题分析能力，基本实现全部综合实践功能；学生较好了解自己负责的任务技术；在演示代码中有自己创作；学生有自己文档写作或文档写作格式规范性较好；学生具有较好的逻辑表达和答辩能力；学生较好表现出团队协作。
$80 \leq$ 良好 <90	学生很好展现其需求问题规格说明和设计问题分析能力，较好实现全部综合实践功能；学生熟练自己负责的任务技术；演示代码基本为自己创作，且有一定难度和工作量；学生文档写作规范性好；学生具有很好的逻辑表达和答辩能力；学生很好地表现出团队协作。
$90 \leq$ 优秀	学生非常好展现其需求问题规格说明和设计问题分析能力，出色实现全部综合实践功能；学生自己负责的任务技术设计很好契合需求；演示代码基本为自己创作，且有难度较高和工作量饱满；学生文档写作规范性好；学生具有很好的逻辑表达和答辩能力，令人印象深刻；学生很好地表现出团队协作，合作气氛较浓。